

REVIEW FINDINGS REPORT

Static Testing & API Design Review

Educational Platform — API Testing

Prepared by: Gehad Zeidan
Version: 1.0

1. Overview

This document contains the static testing and API design review findings identified during the testing of the Educational Platform API (Version 2). These findings were identified through code and design review without test execution.

Field	Details
Project	Educational Platform
Module	Authentication, Verification, Course Management
Document Type	API Review Findings
Prepared By	Gehad Zeidan
Date	May 2026
Total Findings	5

2. Findings Summary

Finding ID	Title	Type	Severity	Priority
RF-001	SendCode uses POST with query params instead of body	Design	Medium	Medium
RF-002	ValidateCode exposes sensitive verification code in URL	Security	High	High
RF-003	Single endpoint handles multiple authentication flows	Design	Medium	Medium
RF-004	Inconsistent response format across Login endpoint	Design	Medium	Medium
RF-005	UpdateUniteById passes content data as query parameters	Design	Medium	Medium

3. Detailed Findings

RF-001 — SendCode Endpoint Design

Finding ID	RF-001
Title	SendCode endpoint uses POST with query params instead of request body
Type	API Design Review Finding

Severity	Medium
Priority	Medium
Review Type	API Design Review
Endpoint	POST /api/Accounts/SendCode
Observation	The SendCode endpoint uses POST method but passes sensitive data (email) as query parameters in the URL instead of the request body.
Evidence	POST /api/Accounts/SendCode?email=user@example.com&isForResetPassword=false
Risk	Email is exposed in the URL which may appear in server logs and browser history.
Recommendation	Move email and isForResetPassword parameters to the request body.

RF-002 — ValidateCode Exposes Sensitive Data in URL

Finding ID	RF-002
Title	ValidateCode exposes sensitive verification code in URL
Type	Security Review Finding
Severity	High
Priority	High
Review Type	Security Review
Endpoint	POST /api/Accounts/ValidateCode
Observation	The verification code is passed as a query parameter in the URL instead of being sent in the request body.
Evidence	POST /api/Accounts/ValidateCode?email=user@example.com&code=711536&isForResetPassword=false
Risk	Sensitive verification code is exposed through browser history, server logs, proxy caching, monitoring tools, and screen visibility.
Expected	POST /api/Accounts/ValidateCodeBody: { "email": "user@example.com", "code": "711536", "isForResetPassword": false }
Recommendation	Move all sensitive parameters (email, code, isForResetPassword) to the request body.

RF-003 — Single Endpoint Handles Multiple Flows

Finding ID	RF-003
-------------------	--------

Title	Single endpoint handles multiple authentication flows
Type	API Design Review Finding
Severity	Medium
Priority	Medium
Review Type	API Design Review
Endpoint	POST /api/Accounts/ValidateCode
Observation	The ValidateCode endpoint uses an isForResetPassword boolean flag to handle two completely different business flows (email confirmation and password reset).
Evidence	Flow 1: POST /api/Accounts/ValidateCode?isForResetPassword=false Flow 2: POST /api/Accounts/ValidateCode?isForResetPassword=true
Impact	Confusing for developers and testers, difficult to maintain, any change affects both flows simultaneously, violates REST API best practices.
Recommendation	Separate into two distinct endpoints: POST /api/Accounts/ValidateEmailCode (Email confirmation only) POST /api/Accounts/ValidateResetCode (Password reset only)

RF-004 — Inconsistent Response Format Across Login Endpoint

Finding ID	RF-004
Title	Inconsistent response format across Login endpoint
Type	API Design Review Finding
Severity	Medium
Priority	Medium
Review Type	Test Execution & API Design Review
Endpoint	POST /api/Accounts/Login
Observation	The Login endpoint returns a JSON object on successful login but returns a plain text string on failed login. This inconsistency makes it harder for API consumers to handle responses uniformly. Discovered during automated testing when JsonPathException was thrown.
Evidence	Success Response <pre>{ "token": "eyJhbGciOiJIUzI1NiIs...", "userName": "admin" }</pre> Failure Response Invalid Email or Password
Impact	API consumers must handle two different response formats for the same endpoint.

	Complicates error handling in frontend code and automated tests.
Recommendation	Return a consistent JSON response structure for both success and failure scenarios. This simplifies client-side implementation and automated testing.

RF-005 — UpdateUniteById Uses Query Parameters Instead of Request Body

Finding ID	RF-005
Title	UpdateUniteById passes content data as query parameters instead of request body
Type	API Design Review Finding
Severity	Medium
Priority	Medium
Review Type	API Design Review
Endpoint	PUT /api/Courses/UpdateUniteById/{id}
Observation	The UpdateUniteById endpoint passes course content fields (Vocabulary, Skill, Translation, Exam, Story) as query parameters in the URL instead of the request body. This is inconsistent with UpdateCourseById which uses JSON Patch body.
Evidence	PUT /api/Courses/UpdateUniteById/15?Vocabulary=Introduction&Skill=Reading&Translation=مرحبا&Exam=Quiz1&Story=Lesson1
Impact	Content data exposed in URL — appears in server logs, browser history, and proxy caching. Inconsistent with UpdateCourseById which uses JSON body.
Recommendation	Move the course content fields to the request body instead of query parameters to follow REST API best practices and prevent exposing data in URLs.

